

Compliance Gap Analysis Report - 2026-04-11

Executive Summary

This report provides a comprehensive analysis of compliance gaps identified during the assessment.

Report Information

Report Date:	2026-04-11 17:51:52
Framework:	NRB CRG 2023
Generated By:	admin

Compliance Score Overview

Overall Compliance Score:	15.26%
Target Score:	85%
Status:	NON-COMPLIANT

Gap Analysis Summary

Total Gaps Identified:	190
Critical Gaps:	161
High Priority Gaps:	28
Medium Priority Gaps:	1
Low Priority Gaps:	0

Compliance Gap Analysis Report - 2026-04-11

Detailed Gap Analysis

Gap #1: Critical Severity

Similarity Score: 0.13

Description: the LI should establish an internal, cross-disciplinary steering committee. it should provide multiple views and perspectives to ensure that the cyber resilience strategy and framework is holistic and focuses on all elements related to people, processes and technology. the steering committee should provide multiple views and perspectives to ensure that the cyber resilience strategy and framework is holistic.

Gap #2: Critical Severity

Similarity Score: 0.19

Description: 2. The LI should ensure that the following aspects are addressed in the strategy: a. The LI's cyber resilience vision and mission;

Gap #3: Critical Severity

Similarity Score: 0.18

Description: 3. The board of the LI should approve the cyber resilience plan and make sure that it is reevaluated and updated on a regular basis in accordance with the LI's threat landscape. III. Cyber Resilience Framework A cyber resilience framework consists of the policies, technical standards, procedures and controls that an LI has established to identify, protect, detect and respond to and recover from the plausible sources of cyber risks it faces. Cyber resilience framework

Gap #4: Critical Severity

Similarity Score: 0.16

Description: 4. The LI should have a cyber resilience framework that clearly sets out how it determines its cyber resilience objectives and risk tolerance, as well as how it effectively identifies, mitigates, and manages its cyber risks to support its objectives.

Gap #5: Critical Severity

Similarity Score: 0.17

Description: 5. The LI's cyber resilience framework should be approved by the LI board to ensure that it is consistent with the organization's developed cyber resilience strategy.

Gap #6: Critical Severity

Similarity Score: 0.16

Description: 6. The LI's cyber resilience framework should be regularly reviewed and updated.

Gap #7: Critical Severity

Similarity Score: 0.12

Description: 7. In particular when there are changes to the LI's cyber resilience strategy or objectives, the cyber resilience framework (containing all policies, technological standards, processes, and controls) should be reviewed and updated. The LI should create a process for review that could consider the factors like: a. current and evolving

Compliance Gap Analysis Report - 2026-04-11

cyberthreats (e.g., those associated with the supply chain, use of cloud services, social media, mobile applications and internet of things);

Gap #8: Critical Severity

Similarity Score: 0.22

Description: 8. The LI's cyber resilience framework should include requirements for timely communication and coordination mechanism so that the LI can work with the relevant parties to successfully respond to and recover from cyberattacks. Enterprise risk management

Gap #9: Critical Severity

Similarity Score: 0.17

Description: 9. The LI's cyber resilience framework should be aligned with its enterprise operational risk management framework and enterprise architecture. An LI's ecosystem

Gap #10: Critical Severity

Similarity Score: 0.22

Description: 10. The LI's cyber resilience framework should consider the cyber risks the LI faces from and poses to its participants, other LIs, suppliers, vendor goods, and its service providers, which are together referred to as an LI's ecosystem. International and national standards

Gap #11: Critical Severity

Similarity Score: 0.15

Description: 11. The LI's cyber resilience framework should employ leading industry-level standards, guidelines, or recommendations (such as the ISO/IEC 27000 series) as benchmarks when developing a framework for cyber resilience and incorporating the best cyber resilience solutions. Risk management governance

Gap #12: Critical Severity

Similarity Score: 0.21

Description: 12. The LI's cyber resilience framework should clearly define roles and responsibilities, including accountability for decision making within institutions for identifying, mitigating and managing risks.

Gap #13: Critical Severity

Similarity Score: 0.17

Description: 13. The LI's cyber resilience framework should systematically incorporate the requirements (i.e., policies, technological standards, and controls) related to governance, identification, protection, detection, reaction, and recovery, testing, situational awareness, and learning and evolution.

Gap #14: Critical Severity

Similarity Score: 0.21

Description: 14. Through independent compliance programs and audits carried out by qualified staff, the LI shall periodically evaluate and measure the sufficiency and effectiveness of its cyber resilience framework (including all security controls) and adherence to it. The LI is encouraged to apply relevant metrics, maturity models, and the results of its testing programs in this process. The LI should routinely order an external audit.

Compliance Gap Analysis Report - 2026-04-11

Gap #15: Critical Severity

Similarity Score: 0.18

Description: 15. The LI should monitor its development of its cyber resilience capabilities on a continuous basis as it progresses from a current state to a defined future state (i.e., a target maturity level).

Gap #16: Critical Severity

Similarity Score: 0.03

Description: 16. The LI should have a strategy for reaching its target level that outlines roadmaps for how it will be resourced and delivered. IV. Role of the Board and Senior Management Board and senior management responsibilities

Gap #17: Critical Severity

Similarity Score: 0.22

Description: 17. The board of the LI is ultimately responsible for making sure that cyber risk is properly managed. The board should establish the LI's cyber risk tolerance and cyber resilience strategy, specify roles and duties for dealing with cyber risk, and endorse the cyber resilience framework.

Gap #18: Critical Severity

Similarity Score: 0.24

Description: 18. The board and senior management should establish a process to ensure that cyber risk is identified and addressed on an ongoing basis. All business units should be involved in the decision to accept, mitigate or avoid these risks, consistent with the LI's risk management framework.

Gap #19: Critical Severity

Similarity Score: 0.19

Description: 19. The LI should develop relevant risk metrics, identifying trends and patterns, to be used by senior management and the board to make risk-informed decisions and to demonstrate progress in the implementation of its cyber resilience framework.

Gap #20: Critical Severity

Similarity Score: 0.20

Description: 20. The board and senior management should ensure that the LI's cyber risks and management of those risks are regularly evaluated during board meetings.

Gap #21: Critical Severity

Similarity Score: 0.22

Description: senior management should closely oversee the implementation of the cyber resilience framework. oversight includes: allocating resources and setting priorities for cyber resilience deliverables based on the findings of cyber resilience assessments, key performance indicators, key risk indicators, overall business goals, and progress toward target maturity.

Gap #22: Critical Severity

Similarity Score: 0.27

Compliance Gap Analysis Report - 2026-04-11

Description: 22. Senior management should make sure that every employee is aware of their responsibility for reducing cyber risk and has access to the necessary training.

Gap #23: Critical Severity

Similarity Score: 0.20

Description: 23. For high-risk employees (e.g., senior management, system administrators, software developers and critical system operators), the board and senior management should create succession plans as necessary. In accordance with established succession plans, they should also create recruitment criteria for critical cyber roles that comprise the necessary cyber skills, expertise, and experience.

Gap #24: Critical Severity

Similarity Score: 0.11

Description: 24. Senior management should help plan and participate in industry-wide drills that test and improve the cyber resilience of the LI's ecosystem. Culture

Gap #25: Critical Severity

Similarity Score: 0.17

Description: 25. In order to foster a culture where workers at all levels are aware that they have important responsibilities for ensuring the LI's cyber resilience, the board and senior management should cultivate a strong level of awareness of and commitment to cyber resilience.

Gap #26: Critical Severity

Similarity Score: 0.22

Description: 26. The senior management of the LI should make sure that everyone within the institution has a better understanding of cyber risk. Training curriculum should be revised frequently to reflect the evolving threat landscape of the ecosystem.

Gap #27: High Severity

Similarity Score: 0.45

Description: 27. The LI should create policies outlining the repercussions for staff members and contractors who don't abide by cyber security regulations. The regulations must be precise and appropriate for the risk and situational context involved.

Gap #28: High Severity

Similarity Score: 0.31

Description: 28. The senior management of the LI should ensure that situational awareness materials are made available to relevant employees when prompted by highly visible cyber incidents, changes to the threat landscapes and the impacts of these threats to the LI. For instance, the LI could send internal emails about cyber events or post articles in their intranet site. Skills

Gap #29: Critical Severity

Similarity Score: 0.20

Description: the board and senior management of the LI should be comprised of individuals who have the right mix of

Compliance Gap Analysis Report - 2026-04-11

expertise, knowledge, and experience to comprehend and control cyber risks. the board should be well-informed to challenge the suggestions and decisions made by the designated senior management in a credible manner.

Gap #30: Critical Severity

Similarity Score: 0.19

Description: 30. A senior executive, such as a Chief Information Security Officer, responsible for carrying out the organization's cyber resilience architecture should be appointed by the board and senior management.

Gap #31: High Severity

Similarity Score: 0.36

Description: 31. The senior management of the LI should ensure that the employees and contractors with privileged accounts who have access to sensitive assets and information need to receive additional cyber resilience training according to the criticality to the business.

Gap #32: Critical Severity

Similarity Score: 0.28

Description: 32. The LI should ensure that this senior executive has: a. sufficient authority and access to required resources (people and technology); b. access to directly report to the board; c. operational independence from other IT operations; and d. the necessary skills and knowledge to successfully plan and execute the LI's cyber resilience initiatives.

Gap #33: Critical Severity

Similarity Score: 0.10

Description: 33. The LI should identify and document all its critical functions, key roles and processes that support those functions, and update this information on a regular basis.

Gap #34: Critical Severity

Similarity Score: 0.15

Description: 34. The LI should identify and document all processes that are dependent on third-party service providers and identify its interconnections, and update this information on a regular basis.

Gap #35: Critical Severity

Similarity Score: 0.07

Description: 35. The LI should perform a business impact analysis to quantify the impact of disruptions on its critical operations.

Gap #36: Critical Severity

Similarity Score: 0.16

Description: 36. The LI should have an enterprise risk management framework to identify risks and conduct risk assessment on a regular basis.

Gap #37: Critical Severity

Similarity Score: 0.12

Compliance Gap Analysis Report - 2026-04-11

Description: 37. The LI should classify its functions and business processes according to their criticality; this information should be used for prioritizing its protective, detective, response and recovery measures.

Gap #38: Critical Severity

Similarity Score: 0.17

Description: 38. The LI should create and maintain a simplified network map of network resources with an associated plan addressing IPs which locate routing and security devices and servers supporting the LI's critical functions which identify links with the outside world.

Gap #39: Critical Severity

Similarity Score: 0.22

Description: 39. The LI should compulsorily conduct the needed risk assessments before deploying new and updated technologies, products, services and connections to identify potential threats and vulnerabilities.

Gap #40: Critical Severity

Similarity Score: 0.24

Description: an LI should be able to identify the information assets supporting its business processes. it should establish a standard for categorizing information and information systems. the LI relies on assets under the direct ownership of the LI and assets that the LI relies on for its critical business operations but are not owned by the LI itself.

Gap #41: Critical Severity

Similarity Score: 0.21

Description: 41. The LI should adopt and apply a cyber security risk assessment process and maintain a risk register to document and monitor risks. The criteria for conducting and/or updating assessments should be specified in the risk assessment process (e.g., system development and renewal, emerging threats, and recognized vulnerabilities inside the LI's systems or infrastructure). The risk register should identify and categorize the risks according to their criticality.

Gap #42: Critical Severity

Similarity Score: 0.26

Description: 42. The LI should conduct and document risk assessments of its information assets in accordance with its cyber security risk assessment process.

Gap #43: Critical Severity

Similarity Score: 0.19

Description: 43. LI should consult and update its risk register based on the outcome or progress of risk assessment results. These results should drive the selection and implementation of security controls, prioritizing them according to the risks faced by the LI.

Gap #44: High Severity

Similarity Score: 0.38

Description: 44. The LI should maintain a central repository of individual and system accounts and permissions. The repository should: a. identify access rights to information assets; b. contain applicable information that will help the LI to identify any anomalous activities; and c. be protected from unauthorized access and modification. Regular review and

Compliance Gap Analysis Report - 2026-04-11

update

Gap #45: Critical Severity

Similarity Score: 0.06

Description: 45. An LI should integrate identification efforts with other relevant processes, such as acquisition and change management. So that it could facilitate a regular review of LI's

Gap #46: Critical Severity

Similarity Score: 0.23

Description: 46. The LI should identify the cyber risks that it bears from or poses to entities in its ecosystem and coordinate with relevant entities, as appropriate. In order to increase the ecosystem's overall resilience, this may involve identifying vulnerabilities and threats that they share and taking appropriate action to mitigate those risks collectively.

Gap #47: Critical Severity

Similarity Score: 0.08

Description: the LI should take into account a wide range of potential threat vectors and risks. this process should include determining the likelihood of a potential threat occurring. the LI should also assess potential risks to the LI's ecosystem.

Gap #48: Critical Severity

Similarity Score: 0.19

Description: 48. The LI must know the services and business operations of the third-party service provider, including details of the services provided by it and the manner in which those services will be delivered, in order to identify and evaluate the risks posed by interconnections with it. The LI may need to rely on various sources to gather this information. For e.g., publicly available data, self-assessments, and third-party assessments to understand, identify, and assess the risks.

Gap #49: Critical Severity

Similarity Score: 0.29

Description: 49. The LI should implement appropriate protective controls that are in line with leading- practice cyber resilience standards such as ISO standards to minimize the likelihood and impact of a successful cyber-attack on identified critical business functions, information assets and data. The current LI standards are not intended to be replaced by the CRG.

Gap #50: Critical Severity

Similarity Score: 0.26

Description: 50. The LI should implement these controls in accordance with the risk analysis completed during the identification phase based on the identification of its critical operations, key roles, procedures, information assets, third-party service providers, and interconnections.

Gap #51: Critical Severity

Similarity Score: 0.25

Description: 51. Protective controls should be proportionate to the LI's threat landscape and systemic role in the financial

Compliance Gap Analysis Report - 2026-04-11

system, and consistent with its risk tolerance.

Gap #52: High Severity

Similarity Score: 0.34

Description: the LI should implement multiple independent security controls at the earliest possible stage. if the system or any of its components are acquired from a third-party supplier, the LI should obtain assurance that the vendor has applied the appropriate security controls.

Gap #53: High Severity

Similarity Score: 0.36

Description: the LI should: a. implement a system development methodology that incorporates resilience by design approach; b. establish and communicate principles for engineering secure systems and ensure processes and procedures are established, documented, maintained and applied to information system implementation efforts. each environment should be properly secured in accordance with the security standards of the LI; e. assess the effectiveness of the security controls regularly to adapt them to its evolving threat landscape.

Gap #54: High Severity

Similarity Score: 0.48

Description: protection mechanisms should include scanning, blocking and/or quarantine at network entry and exit points, email gateways, servers and end systems. LI personnel should be trained on the effective use of anti-malware software; b. protection against phishing attacks; c. integrity verification tools to detect unauthorized changes to critical files.

Gap #55: High Severity

Similarity Score: 0.45

Description: the LI should implement strong communications and network security controls. that includes, but are not limited to: a. implementation of secure network protocols and encryption to protect the confidentiality and integrity of information exchanged within its network and beyond. b. a broad range of technologies and tools to detect and block actual and attempted attacks or intrusions, including those from authorized third-party connections.

Gap #56: Critical Severity

Similarity Score: 0.13

Description: 56. The LI should have a configuration and change management policy, process and procedures in place. The configuration and change management process should be based on well-established and industry-recognized standards and best practices (e.g., an

Gap #57: High Severity

Similarity Score: 0.38

Description: the LI should configure ICT systems and devices with security settings that are consistent with the level of protection defined in its security policy. the baseline system security configuration standards should prescribe technical IT security controls, parameters, features and specifications required to achieve the LI's cyber security goals.

Gap #58: Critical Severity

Compliance Gap Analysis Report - 2026-04-11

Similarity Score: 0.23

Description: the LI should: a. define and document the baseline profile of system activities, proportionate to risk, to help detect deviation from the baseline (e.g., anomalous activities and events) the baseline profile should address system-level technical activities (such as regular network traffic patterns, account usage and access patterns) and the system's business activities (such as participants' regular or expected transaction frequency, size, timing and volume)

Gap #59: High Severity

Similarity Score: 0.36

Description: 59. Where it is feasible and practical, the LI should develop the necessary capabilities to block suspected activity at the application and/or network in order to contain anomalous activity;

Gap #60: High Severity

Similarity Score: 0.46

Description: the secure boundary should identify trusted and untrusted zones (DMZ) according to the cyber risk profile and criticality of information assets contained within each security zone. a deny-all, permit-by- exception traffic policy should be used between zones where possible; b. manage and control networks to protect information.

Gap #61: Critical Severity

Similarity Score: 0.18

Description: 61. The LI should implement protective measures to mitigate risks arising from the entities in its ecosystem. The results of the risk assessment from the identification phase,

Gap #62: High Severity

Similarity Score: 0.41

Description: an LI should specify participation requirements to ensure that it can meet its cyber resilience objectives. the LI should impose rules in the following areas, but are not limited to: a. connectivity restrictions, b. access control and privileged account management, c. identification and authentication management, d. confidentiality and integrity protection via encryption, f. detection and response management, and g. security awareness and training.

Gap #63: Critical Severity

Similarity Score: 0.19

Description: 63. The LI should obtain assurance from its participants that they meet the LI's cyber resilience requirements. The assurance can be in the form of participant self-attestations or external third-party certifications of the participant's resilience. Third-party cyber resilience

Gap #64: Critical Severity

Similarity Score: 0.22

Description: the LI should request confirmation that its third-party vendors and service providers meet its requirements for cyber resilience. contracts should cover matters such as: a. validation of security capabilities. an LI could request a self-assessment or a third-party assessment.

Gap #65: High Severity

Similarity Score: 0.31

Compliance Gap Analysis Report - 2026-04-11

Description: insider threats can put the LI's employees, customers, assets, reputation and interests at risk. insider threats can put the LI's employees, customers, assets, reputation and interests at risk. the LI should update its risk profile component related to third-party.

Gap #66: High Severity

Similarity Score: 0.32

Description: 66. The LI should implement measures to monitor anomalous behavior by users of its systems. It should use data loss identification and prevention techniques in order to prevent removal of sensitive and confidential data from its network. Changes in employment status

Gap #67: Critical Severity

Similarity Score: 0.26

Description: 67. In order to reduce insider threats, an LI should screen and background-check new employments. Similar checks should be performed on every employee periodically throughout their employment, commensurate with access to critical systems by the staff. The LI should set up processes and controls to mitigate risks associated with employees quitting their jobs or changing their responsibilities.

Gap #68: High Severity

Similarity Score: 0.33

Description: the LI should incorporate cyber security at every stage of the employment life cycle. this includes: a. conducting pre-employment background security checks on all successful candidates (employees and/or contractors) based on their potential roles and the importance of the resources and information they might need to perform their duties.

Gap #69: Critical Severity

Similarity Score: 0.28

Description: 69. All employees, contractors, and outside parties should be required to wear identity card issued by the institution. Security personnel should be alerted right away if they encounter anyone not wearing the identity card issued by the institution.

Gap #70: Medium Severity

Similarity Score: 0.62

Description: 70. Access to secure areas or confidential information processing facilities, including for outside support staff, should only be granted only when necessary. Such access should be authorized and monitored. Access control
Logical access

Gap #71: High Severity

Similarity Score: 0.32

Description: the LI should ensure that identity verification is carried out by the participating entity. all internal (e.g., employees and contractor) as well as external users (e.g., LI participants) have been uniquely identified and authenticated so that actions and activities can be attributed to individual users. the authentication mechanism should be set as per the criticality of the information system, processes, and/or user roles.

Compliance Gap Analysis Report - 2026-04-11

Gap #72: High Severity

Similarity Score: 0.33

Description: critical computing equipment should be physically protected with features like water damage protection, fire suppression systems, temperature and humidity controls, and emergency power and lighting. wireless access points, power cables, and telecommunications cabling related to critical systems should be protected from tampering and damage.

Gap #73: High Severity

Similarity Score: 0.47

Description: 73. Information security should be complied by all employees (including senior management and board members) and contractors in accordance with the LI's established cyber resilience policies, technical standards, and procedures. LI staff

Gap #74: Critical Severity

Similarity Score: 0.27

Description: the LI should: a. make sure that all employees, whether they are full-time or temporary, receive training to help them develop and maintain the necessary awareness and skills for identifying and addressing cyber-related risks. b. train staff on how to report any unusual activity and incidents (e.g., phishing attempts, requests for sensitive information or passwords, and requests from unidentified sources); d. include a course on cyber security awareness

Gap #75: Critical Severity

Similarity Score: 0.29

Description: 75. The LI should identify staff members and subcontractors in high-risk groups, such as those with privileged system access or in delicate business roles, and give them specialized information security training.

Gap #76: High Severity

Similarity Score: 0.33

Description: 76. The LI should implement continuous monitoring against the baseline profile of system activities discussed in the title Layered protection that facilitates response and recovery (Page No. 20) of sub-section: II. Protection of processes and assets under the section: D. Protection.

Gap #77: Critical Severity

Similarity Score: 0.25

Description: the LI should: a. develop and implement automated detection systems (for e.g., a security information and event management system) that correlate all network and system alerts with any other unusual activity across all of its business units. b. have capabilities to monitor: i. user activity, exceptions and cyber security events; ii. network connections, external service providers, devices and software.

Gap #78: Critical Severity

Similarity Score: 0.17

Description: the LI should collect, monitor and analyze patterns and behavior (e.g., network use patterns, work hours and known devices, etc.) this will help to identify anomalous activities and evaluate the implementation of emerging

Compliance Gap Analysis Report - 2026-04-11

solutions (e.g., data analytics, machine learning and artificial intelligence, etc.) and controls to support detection and response to insider threat activity in real time.

Gap #79: High Severity

Similarity Score: 0.30

Description: the LI should use detection capabilities by implementing multi-layered detection controls that cover people, processes, and technology. an effective intrusion detection capability could help an LI identify flaws in its protective measures and correct them as soon as possible.

Gap #80: Critical Severity

Similarity Score: 0.19

Description: 80. The LI should constantly investigate new technologies and techniques to prevent lateral movement. These technologies and techniques should trigger alerts and notify the LI of any potential malicious activity.

Gap #81: Critical Severity

Similarity Score: 0.11

Description: 81. The LI should ensure its detection capabilities are periodically reviewed, tested and updated appropriately. Incident response An LI's monitoring and detection capabilities should facilitate its incident response process and support information collection for the forensic investigation process.

Gap #82: Critical Severity

Similarity Score: 0.12

Description: 82. The monitoring and detection capabilities of the LI should send a notification to the concerned staff.

Gap #83: High Severity

Similarity Score: 0.36

Description: 83. To facilitate forensic investigation, the LI should ensure that: a. anomalies and events that are detected are recorded in event or system logs; b. there is enough storage capacity for the necessary logs; and c. the logs' content includes the necessary information to support investigation (e.g., event type, time, user/address, and so on); d. audit data and tools are protected against unauthorized access, modification, or deletion.

Gap #84: Critical Severity

Similarity Score: 0.23

Description: 84. The LI should ensure that its logs are backed up in a secure location and that controls are in place to mitigate the risk of alteration.

Gap #85: Critical Severity

Similarity Score: 0.17

Description: 85. The LI should implement a time synchronization capability to ensure that correlated logs have consistent times. Security analytics

Gap #86: Critical Severity

Similarity Score: 0.22

Compliance Gap Analysis Report - 2026-04-11

Description: 86. The LI should have a process to collect, centralize and correlate event information (including anomalous activity) from multiple sources and log analysis to continuously monitor the IT environment (e.g., databases, servers and end points, etc.). This capability could be achieved through a security operations center (SOC), network operations center or equivalent.

Gap #87: Critical Severity

Similarity Score: 0.19

Description: 87. The LI should have a comprehensive cyber incident response capability that includes detection and analysis as well as containment, elimination, and recovery; and post- incident activity. This capability could include direct cooperative or contractual agreements with incident response organizations or providers to help with mitigation efforts as quickly as possible.

Gap #88: Critical Severity

Similarity Score: 0.20

Description: 88. The LI should also have the resources, policies, and procedures in place to conduct a thorough investigation of a cyber-attack including root cause analysis. The LI may use internal resources and/or third-party service providers with whom it has contractual agreements to ensure that the investigation begins as soon as a cyber-attack is detected.

Gap #89: Critical Severity

Similarity Score: 0.16

Description: 89. When a successful or attempted cyber-attack is detected and confirmed, the LI should deploy its investigative capability to determine the nature and extent of the attack, as well as the damage inflicted.

Gap #90: Critical Severity

Similarity Score: 0.11

Description: 90. While the investigation is ongoing, the LI should take immediate action to contain the cyber-attack or attempted cyber-attack to prevent further damage and begin efforts to resume operations based on its response planning.

Gap #91: Critical Severity

Similarity Score: 0.23

Description: 91. Based on the potential impact and criticality of the risk, the LI should establish criteria and procedures for escalating cyber incidents to the board and senior management.

Gap #92: Critical Severity

Similarity Score: 0.19

Description: 92. The LI should also have procedures to escalate investigations to law enforcement agencies as needed.

Gap #93: Critical Severity

Similarity Score: 0.18

Description: 93. The LI should ensure that its incident response team has the requisite skills and training to address cyber incidents.

Compliance Gap Analysis Report - 2026-04-11

Gap #94: Critical Severity

Similarity Score: 0.09

Description: 94. The LI should train its employees so that they understand their roles and responsibilities in handling digital evidence and ensuring that it is not compromised and remains valid in accordance with the requirements of the local jurisdiction. Resumption within two hours (i.e., two-hour RTO)

Gap #95: Critical Severity

Similarity Score: 0.03

Description: 95. Objectives for resuming operations should be planned for and tested. In line with key consideration 17.6 of the PFMI, a LI should design and test its systems and processes to enable: a. the safe resumption of critical operations within two hours of a disruption; and b. completion of settlement by the end of the day of the disruption, even in the case of extreme but plausible scenarios.

Gap #96: Critical Severity

Similarity Score: 0.12

Description: planning to enable resumption within two hours of a cyber incident requires a detailed and comprehensive understanding of the LI's functions and processes. an LI should involve both the technical and business teams to carefully plan for risks specific to the LI's design, critical functions and processes.

Gap #97: Critical Severity

Similarity Score: 0.10

Description: the LI should aim to resume critical operations safely within two hours of a disruption. it should also prepare for scenarios in which this objective is not achieved. the LI should also plan for situations in which critical people, processes or systems may be unavailable for significant periods.

Gap #98: Critical Severity

Similarity Score: 0.01

Description: 98. The LI should devise a backup plan based on scenarios in which resumption within two hours is not possible. This strategy should include: a. address how the LI could achieve its recovery objectives and restoration priorities; b. define roles and responsibilities; and c. set out options for rerouting or substituting critical functions and/or services that may be affected for an extended period of time by a successful cyber-attack.

Gap #99: Critical Severity

Similarity Score: 0.01

Description: 99. Based on their relative priorities and reliable information related to resumption possibility, the LI must plan for how to operate in a reduced capacity or how to safely restore services over time. Planning and preparation

Gap #100: Critical Severity

Similarity Score: 0.04

Description: the LI should develop comprehensive cyber incident response, resumption, and recovery plans. these plans should aim to limit damage and prioritize resumption and recovery actions that facilitate critical transaction processing while reducing recovery time and costs. following should be considered while developing these plans.

Compliance Gap Analysis Report - 2026-04-11

Gap #101: Critical Severity

Similarity Score: 0.12

Description: 101. Response, resumption, and recovery plans should define policies and procedures, as well as roles and responsibilities for escalating, responding to, and recovering from cyber incidents.

Gap #102: Critical Severity

Similarity Score: 0.05

Description: 102. In developing its plans, the LI should: a. include a range of extreme but plausible scenarios to assess the potential impact of such scenarios on the LI and the broader ecosystem; and b. consult and coordinate with all relevant business units and external stakeholders.

Gap #103: Critical Severity

Similarity Score: 0.08

Description: 103. The LI should regularly update its plans. This includes: a. reviewing its range of scenarios; b. conducting business impact assessments in line with the evolving threat landscape; and c. incorporating lessons learned from previous cyber incidents, including root cause analysis findings

Gap #104: Critical Severity

Similarity Score: 0.02

Description: 104. The LI should test its response, resumption, and recovery plans against a variety of scenarios on a regular basis.

Gap #105: Critical Severity

Similarity Score: 0.00

Description: 105. The LI should consult with relevant external stakeholders (e.g., participants, service providers and other LIs) within the ecosystem to improve its response, resumption, and recovery plans.

Gap #106: Critical Severity

Similarity Score: 0.10

Description: 106. The LI should put in place processes to improve its response, resumption, and recovery plans on a continuous basis, considering cyber threat intelligence sources (e.g., feeds) and information shared within its ecosystem.

Gap #107: Critical Severity

Similarity Score: 0.04

Description: the LI's cyber incident response, resumption and recovery processes should be closely integrated with crisis management, business continuity, and disaster recovery planning and operations. design of business processes, information systems, and response and recovery controls have a significant influence on the LI's ability to resume critical operations within two hours.

Gap #108: Critical Severity

Similarity Score: 0.15

Compliance Gap Analysis Report - 2026-04-11

Description: 108. System and process design and controls for critical function and operation should support incident response activities as much as possible.

Gap #109: Critical Severity

Similarity Score: 0.17

Description: 109. The LI should design systems and processes to minimize the impact of any cyber incident, to resume critical operations within two hours of a disruption, to complete settlement by the end of the day, and to maintain transaction integrity.

Gap #110: Critical Severity

Similarity Score: 0.13

Description: 110. When designing its systems and processes, the LI should consider a variety of scenarios and potential response actions, as well as their implications.

Gap #111: Critical Severity

Similarity Score: 0.00

Description: the objective of resuming operations within two hours requires careful selection and implementation techniques and methods of settlement. the solutions chosen will be determined by several factors, including the system's design and complexity, the frequency and volume of transactions, and the system's life-cycle stage.

Gap #112: Critical Severity

Similarity Score: 0.13

Description: 112. The LI should define and identify data that is critical for the resumption of services which should be backed up. The data types that are necessary for resumption include not only transactional data but also other critical data, such as source code, business reference data

Gap #113: Critical Severity

Similarity Score: 0.26

Description: 113. The LI should have plans in place to quickly determine the status of all transactions and member positions in the event of a disruption, backed up by recovery point objectives. As a result, the LI should design and test its systems and processes to ensure recovery of accurate data following a breach. Stringent protection and detection controls should be used to protect information and data.

Gap #114: Critical Severity

Similarity Score: 0.08

Description: 114. Recovery point objectives to support data integrity efforts should be consistent with the LI's resumption time objective for critical operations.

Gap #115: Critical Severity

Similarity Score: 0.11

Description: 115. Recovery point objectives and data recovery options should be established in close collaboration with the business and IT functions. This close collaboration can assist an organization in answering fundamental questions about how to conduct critical business processes in the face of corruption.

Compliance Gap Analysis Report - 2026-04-11

Gap #116: Critical Severity

Similarity Score: 0.14

Description: 116. The backup solutions provided by the LI should be configured to align with the frequency and volume of transactions. Because an LI processes thousands of transactions per hour, a solution that only backs up once per day will not provide adequate protection unless additional database transaction recovery solutions are implemented.

Gap #117: Critical Severity

Similarity Score: 0.00

Description: 117. The backup and recovery methods and strategies should be integrated into LI's system infrastructure at the development and/or acquisition phase.

Gap #118: Critical Severity

Similarity Score: 0.14

Description: 118. The LI should back up its information system by maintaining a redundant secondary system that is not located in the same place as the primary system and that can be activated without information being lost or operations disrupted.

Gap #119: Critical Severity

Similarity Score: 0.12

Description: 119. Data recovery measures should be included in the LI's cyber resilience framework. The LI should consider a variety of options for data recovery. The LI should choose these options based on a detailed analysis of what data are critical to the LI's operations, including what data the LI would need to resume operations within two hours and how various cyber scenarios, including data loss and manipulation of data, could impact the integrity of these data.

Gap #120: Critical Severity

Similarity Score: 0.30

Description: 120. Backups should be protected both at rest and in transit to ensure data confidentiality, integrity, and availability. Backups should be tested on a regular basis to ensure their availability and integrity.

Gap #121: Critical Severity

Similarity Score: 0.16

Description: 121. The range of data recovery options that the LI should consider include, but are not limited, to: a. implementing database record recovery mechanisms, such as record rollback and logging or rolling forward to correct corrupted data; b. conducting more frequent independent reconciliation of participants' positions; c. keeping a copy of all received and processed data and related information; and

Gap #122: Critical Severity

Similarity Score: 0.23

Description: 122. The LI should have a data-sharing agreement in place with third parties and/or participants, as appropriate, to facilitate obtaining uncorrupted data from them, if necessary, for resuming its business operations in a timely manner and with accurate data.

Compliance Gap Analysis Report - 2026-04-11

Gap #123: High Severity

Similarity Score: 0.41

Description: 123. The LI should review information-sharing rules, agreements, and protocols on a regular basis in order to control the publication and distribution of such information and to prevent the disclosure of sensitive information that could have adverse consequences if disseminated improperly. Contagion

Gap #124: Critical Severity

Similarity Score: 0.18

Description: an LI may pose or be exposed to contagion risk (i.e., spread of malware or corrupted data) to or from its ecosystem. it should develop policies and procedures outlining how it will collaborate with relevant interconnected entities to resume operations.

Gap #125: Critical Severity

Similarity Score: 0.12

Description: 125. The LI should develop a communication plan and procedures for communicating with participants, linked FMs, authorities, and others (e.g., service providers and media, where relevant). The LI's communication plan should be informed by scenario-based planning and analysis as well as previous experience.

Gap #126: Critical Severity

Similarity Score: 0.07

Description: 126. The incident response plan for the LI should identify internal and external stakeholders who must be notified, decision-making responsibilities and authorities, and information that must be shared and reported, as well as when this should take place.

Gap #127: Critical Severity

Similarity Score: 0.24

Description: 127. Any cyber incident that could be material or systemic should be immediately reported to relevant oversight and regulatory authorities by the LI. The LI should follow the requirements of NRB's related directive/guideline when reporting cyber incidents to the NRB.

Gap #128: Critical Severity

Similarity Score: 0.25

Description: 128. When there are indications of criminal intent (e.g., fraud, extortion), the LI should have procedures in place to escalate investigations to law enforcement agencies. Responsible disclosure policy

Gap #129: High Severity

Similarity Score: 0.31

Description: 129. The LI should have a policy and procedures in place to allow for the responsible disclosure of potential vulnerabilities and risks within its ecosystem as it responds in real time to a cyber-attack or incident.

Gap #130: Critical Severity

Similarity Score: 0.19

Compliance Gap Analysis Report - 2026-04-11

Description: 130. The LI should prioritize disclosures that will assist participants and other stakeholders in responding quickly and mitigating their own risk, which will benefit the ecosystem and overall financial stability. Forensic readiness

Gap #131: Critical Severity

Similarity Score: 0.27

Description: 131. The LI should develop the capability to support or assist in forensic investigations. This capability should include the ability to design protective and detective controls to aid in the investigation process. The LI should establish relevant system logging policies, such as required audit log content, log and event time synchronization, and log file retention periods.

Gap #132: Critical Severity

Similarity Score: 0.25

Description: 132. The LI should establish procedures for securely handling, collecting, and preserving digital evidence while ensuring its authenticity and integrity, so that forensic investigations can be conducted after the event or after critical operations resume.

Gap #133: Critical Severity

Similarity Score: 0.09

Description: 133. The LI should closely integrate plans for forensic readiness with plans for incident management and other related business planning activities.

Gap #134: Critical Severity

Similarity Score: 0.16

Description: 134. The LI should train its staff so that all those involved in the particular incident understand their responsibilities related to handling the digital evidence, ensuring it is not compromised and valid as per the local jurisdiction.

Gap #135: Critical Severity

Similarity Score: 0.14

Description: 135. As part of its cyber resilience framework, the LI should establish and maintain a comprehensive testing program. The testing program should be developed using a risk- based approach and include a wide range of methodologies, practices, and tools for monitoring, assessing, and evaluating the effectiveness of the cyber resilience framework's core components.

Gap #136: Critical Severity

Similarity Score: 0.18

Description: 136. The testing program should be reviewed and updated on a regular basis, taking into account the evolving threat landscape and the criticality of information assets.

Gap #137: Critical Severity

Similarity Score: 0.08

Description: 137. When implementing its testing program, the LI should develop appropriate capabilities and involve all relevant internal stakeholders (including business lines and operational

Compliance Gap Analysis Report - 2026-04-11

Gap #138: Critical Severity

Similarity Score: 0.10

Description: 138. To improve its cyber resilience stance, the LI should also collaborate with entities in its ecosystem. This collaboration helps to strengthen the LI's ecosystem's resilience.

Gap #139: Critical Severity

Similarity Score: 0.04

Description: 139. The LI should involve its board and senior management appropriately (e.g., as members of crisis management teams) and inform them of test results.

Gap #140: Critical Severity

Similarity Score: 0.12

Description: 140. To continuously improve its cyber resilience stance, the LI should establish policies and procedures to prioritize and resolve issues identified during the various tests, as well as perform subsequent validation to determine whether gaps have been addressed sufficiently.

Gap #141: Critical Severity

Similarity Score: 0.10

Description: 141. The LI should ensure that the tests are carried out by independent parties, whether internal or external. Methodologies, practices and tools

Gap #142: Critical Severity

Similarity Score: 0.12

Description: 142. The LI should use a wide range of testing methodologies, practices, and tools, such as vulnerability assessments, scenario-based testing, penetration tests, and red team tests (which may overlap partly or be combined). Vulnerability assessment

Gap #143: Critical Severity

Similarity Score: 0.10

Description: 143. The LI should develop and regularly update a vulnerability management process to classify, prioritize, and resolve potential vulnerabilities identified in vulnerability assessments, as well as perform subsequent validation to determine whether gaps have been addressed sufficiently.

Gap #144: Critical Severity

Similarity Score: 0.23

Description: 144. The vulnerability management process of the LI should help identifying exploitable weakness (which is a susceptibility or flaw in a system that an attacker can access and exploit to compromise system security) in critical systems and technologies, as well as conditions that allow for human error and accidents in critical functions, supporting processes, and information assets.

Gap #145: Critical Severity

Similarity Score: 0.16

Compliance Gap Analysis Report - 2026-04-11

Description: 145. The LI should conduct vulnerability scanning of its external-facing services as well as internal systems and networks on a regular basis. These scans should rotate between environments to ensure that they reach all environments throughout the year.

Gap #146: Critical Severity

Similarity Score: 0.14

Description: 146. The LI should conduct vulnerability assessments to identify bugs and weaknesses before deploying or redeploying new or existing services supporting critical functions, applications, and infrastructure components. These assessments should be performed on a regular basis, with change and release management processes in place.

Gap #147: Critical Severity

Similarity Score: 0.24

Description: 147. The LI should conduct vulnerability assessments on running services, applications, and infrastructure components on a regular basis. It should monitor and evaluate the effectiveness of security controls to address identified vulnerabilities, as well as check for compliance with regulations, policies, and configurations.

Gap #148: Critical Severity

Similarity Score: 0.12

Description: 148. As part of its vulnerability management process, the LI should develop and implement a variety of effective practices and tools (for e.g., a bug bounty program or static and dynamic code reviews), as well as appropriate safeguards to manage them. Scenario-based testing

Gap #149: Critical Severity

Similarity Score: 0.06

Description: the LI should conduct various scenarios-based tests, including extreme but plausible scenarios. the latter should be reviewed and tested on a regular basis. a team discusses their roles and responses during an emergency, walking through one or more example scenarios.

Gap #150: Critical Severity

Similarity Score: 0.14

Description: the LI should design tests that: a. address a sufficiently broad range of scenarios, such as simulation of extreme but plausible cyber-attacks; b. are intended to challenge the assumptions of response, resumption, and recovery practices. e. cover breaches affecting multiple components of the LI's ecosystem in order to identify and analyze potential complexities, interdependencies, and potential contagion at the business and operational levels.

Gap #151: Critical Severity

Similarity Score: 0.22

Description: 151. The LI should use cyber threat intelligence (CTI) and cyber threat modelling to imitate the unique characteristics of cyber threats, to the extent possible.

Gap #152: Critical Severity

Similarity Score: 0.08

Description: 152. In order to achieve greater operational resilience, the LI should also conduct exercises to test

Compliance Gap Analysis Report - 2026-04-11

processes and staff's ability to respond to unfamiliar scenarios.

Gap #153: Critical Severity

Similarity Score: 0.12

Description: 153. The LI should collaborate with the ecosystem to develop cybersecurity incident scenarios involving significant financial loss and use them for stress tests to understand potential spill overs and contagion risk to the ecosystem. With the help of the stress tests, it will improve its cyber resilience postures contributing to the improvement of the ecosystem's resilience as a whole.

Gap #154: Critical Severity

Similarity Score: 0.05

Description: 154. When appropriate, the LI's board of directors and senior management should involve in scenario-based testing.

Gap #155: Critical Severity

Similarity Score: 0.19

Description: 155. Penetration tests should be performed by the LI to identify vulnerabilities that may affect its systems, networks, applications, people, or processes. These tests should simulate actual attacks on the LI's systems in order to provide an in-depth evaluation of their security.

Gap #156: Critical Severity

Similarity Score: 0.09

Description: 156. Penetration tests should be conducted regularly and whenever there are major updates to or deployment of systems.

Gap #157: Critical Severity

Similarity Score: 0.13

Description: 157. The LI should include all critical internal and external stakeholders in penetration testing exercises, as appropriate. Application and system owners, as well as business continuity and incident and crisis response teams, could be among these stakeholders.

Gap #158: Critical Severity

Similarity Score: 0.17

Description: 158. The LI should incorporate testing practices into its enterprise risk management process in order to identify, analyze, and fix cyber security vulnerabilities caused by new products, services, or interconnections.

Gap #159: Critical Severity

Similarity Score: 0.22

Description: 159. The LI should perform security assessments and tests at all stages of the system development life cycle and at any level (business, application, and technology) for the entire application portfolio, including mobile applications.

Gap #160: Critical Severity

Compliance Gap Analysis Report - 2026-04-11

Similarity Score: 0.08

Description: 160. The LI should implement best practices and automated tools to support processes and procedures for fixing technical and organizational weaknesses identified during testing exercises and ensuring compliance with approved policies and configurations. Red team testing

Gap #161: Critical Severity

Similarity Score: 0.21

Description: 161. The LI should use so-called red teams to introduce an adversary perspective in a controlled setting to challenge its own organization and ecosystem. Red teams test potential vulnerabilities as well as the effectiveness of an LI's mitigating controls, which include people, processes, and technology.

Gap #162: Critical Severity

Similarity Score: 0.13

Description: 162. A red team can be made up of LI employees as well as outside experts who are, in either case, independent of the function being tested. The red team should conduct regular exercises and collaborate with its cyber defense team (e.g., blue team) to share findings and improve the LI's cyber resilience stance.

Gap #163: Critical Severity

Similarity Score: 0.15

Description: 163. The LI should also use appropriate cyber threat intelligence (CTI) to inform its testing methods, such as by designing tests to simulate advanced threat agent capabilities and extreme but plausible scenarios. The LI should conduct red team exercises based on specific and plausible threat scenarios, using reliable and valuable CTI.

Gap #164: Critical Severity

Similarity Score: 0.09

Description: 164. The LI should proactively engage in industry-wide exercises in order to test cooperation and coordination protocols and communication plans. These exercises should foster the LI's awareness on cross-sector cooperation and third-party risks.

Gap #165: Critical Severity

Similarity Score: 0.00

Description: 165. To the extent practicable and feasible, the LI should promote, organize, and manage exercises designed to test its response, resumption, and recovery plans and processes. Such exercises should include LI participants, critical service providers, and linked FMIs, as appropriate.

Gap #166: Critical Severity

Similarity Score: 0.03

Description: 166. The LI should take part in industry-wide tests and exercises organized by the relevant authorities. Achieving timely resumption of operations market-wide calls for an added dimension to testing exercises. Traditional isolated testing implicitly assumes that all other players are carrying out their operations as usual.

Gap #167: Critical Severity

Similarity Score: 0.10

Compliance Gap Analysis Report - 2026-04-11

Description: 167. Testing should include scenarios that cover breaches affecting multiple components of the LI's ecosystem.

Gap #168: Critical Severity

Similarity Score: 0.24

Description: the LI should include in its threat analysis those threats that could cause extreme but plausible cyber events. this analysis should be regularly reviewed and updated. the LI should include in its threat analysis those threats that could cause extreme but plausible cyber events.

Gap #169: Critical Severity

Similarity Score: 0.28

Description: the LI should include internal and external business and system information in its analysis to provide a business-specific context. this will turn information into usable CTI that provides timely insights and inform enhanced decision-making by enabling the LI to anticipate a cyber attacker's capabilities, intentions and modus operandi.

Gap #170: High Severity

Similarity Score: 0.33

Description: 170. To acquire threat information, the LI should belong or subscribe to a threat and vulnerability information-sharing source and/or information-sharing and analysis center that provides information on cyber threats and vulnerabilities, where available.

Gap #171: Critical Severity

Similarity Score: 0.27

Description: 171. The LI's cyber threat information should include analysis of real-world attackers' tactics, techniques, and procedures, as well as information on geopolitical developments that may trigger cyber-attacks on any entity within the LI's ecosystem.

Gap #172: High Severity

Similarity Score: 0.39

Description: the LI should use threat information collected from different sources to determine threat actors' motivations and capabilities. a. reassess the risk of technical vulnerabilities in operating systems, applications, and other software that could be exploited to launch attacks on the LI; c. analyze cyber security incidents experienced by other organizations.

Gap #173: Critical Severity

Similarity Score: 0.27

Description: 173. The LI should continuously use the CTI it has developed to assess and manage security threats and vulnerabilities in order to implement threat-informed cyber security controls in its systems and, more broadly, to continuously improve its cyber resilience framework and capabilities.

Gap #174: Critical Severity

Similarity Score: 0.08

Description: the LI should use information from its SOC to improve its CTI. c. use CTI to help inform and update its

Compliance Gap Analysis Report - 2026-04-11

testing program to ensure it is up-to-date with latest threat landscape, attackers' tactics, and vulnerabilities.

Gap #175: Critical Severity

Similarity Score: 0.20

Description: the LI should define its information-sharing objectives in line with its business objectives and cyber resilience framework. its objectives should include timely gathering and exchanging information that could facilitate in the detection, response, resumption, and recovery of its own systems.

Gap #176: High Severity

Similarity Score: 0.37

Description: 176. The LI should establish and review its information-sharing rules and agreements on a regular basis. It should implement procedures that allow information to be shared promptly and in accordance with the objectives and scope define in the information- sharing rules and agreements, while also meeting its obligations to protect potentially sensitive data, the improper disclosure of which could have adverse consequences.

Gap #177: High Severity

Similarity Score: 0.39

Description: 177. The LI should establish and implement protocols with employees for sharing information relating to threats, vulnerabilities and cyber incidents, based on their specific roles and responsibilities. Information-sharing groups

Gap #178: Critical Severity

Similarity Score: 0.25

Description: 178. The LI should participate actively in existing information-sharing groups and facilities, including cross-industry, cross-government and cross-border groups, to gather, distribute and assess information about cyber practices, cyber threats and early warning indicators related to cyber threats.

Gap #179: Critical Severity

Similarity Score: 0.27

Description: 179. The LI should consider exchanging information on its cyber resilience framework with trusted stakeholders, as needed, to promote understanding of each other's approach to securing systems that are linked or interfaced. Such information exchange would help an LI and its stakeholders coordinate their respective security measures in order to achieve greater cyber resilience.

Gap #180: Critical Severity

Similarity Score: 0.18

Description: 180. The LI should participate in efforts to identify and address gaps in current information- sharing mechanisms in order to facilitate an ecosystem-wide response to large-scale incidents.

Gap #181: Critical Severity

Similarity Score: 0.26

Description: 181. In the event of an incident, the LI should plan for information-sharing through trusted channels, collecting and exchanging timely information that could facilitate the detection, response, resumption, and recovery of its own systems and those of other entities within the LI's ecosystem during and after a cyber-attack.

Compliance Gap Analysis Report - 2026-04-11

Gap #182: Critical Severity

Similarity Score: 0.16

Description: 182. To enhance its cyber resilience capabilities, the LI should identify and categorize lessons learned (strategic, tactical, and operational) from real-life cyber incidents, both internal and external to the LI.

Gap #183: Critical Severity

Similarity Score: 0.15

Description: 183. To improve its risk mitigation capabilities as well as its cyber response, resumption, recovery, and contingency plans, the LI should incorporate these key lessons learned from real-life cyber incidents and/or results of testing on the LI and/or other organizations.

Gap #184: Critical Severity

Similarity Score: 0.27

Description: 184. When highly visible cyber events or regulatory alerts occur, the LI should ensure that cyber security awareness materials are made available to staff.

Gap #185: Critical Severity

Similarity Score: 0.07

Description: 185. The LI should incorporate lessons learned into staff training, awareness programs, and materials, on an ongoing and dynamic basis, and validate their effectiveness. The LI should utilize industry and authority initiatives related to awareness and training, where possible. Acquiring new knowledge and capabilities

Gap #186: Critical Severity

Similarity Score: 0.12

Description: 186. The LI should: a. confirm that it has a program for continuous cyber resilience training. This training program should be conducted to board members and senior management at least once a year. Incident response, current cyber threats, and emerging issues (e.g., spear

Gap #187: High Severity

Similarity Score: 0.31

Description: cyber risk management practices should include proactive protection against future cyber events. the LI should strive for predictive capabilities by collecting data from multiple internal and external sources, defining a baseline for behavioral and system activity, and analyzing activities that deviate from the baseline.

Gap #188: Critical Severity

Similarity Score: 0.15

Description: metrics and maturity models enable an LI to assess its cyber resilience maturity in relation to a set of predefined criteria. the LI must analyze and correlate findings from audits, vulnerability assessments, management information, incidents, near misses, tests, and exercises with external and internal intelligence.

Gap #189: Critical Severity

Similarity Score: 0.02

Compliance Gap Analysis Report - 2026-04-11

Description: 189. To assess the performance and effectiveness of its testing program, the LI should develop, monitor, and analyze metrics. The LI should use the results of the analysis to improve its testing program.

Gap #190: Critical Severity

Similarity Score: 0.10

Description: 190. The LI should create a set of indicators and management information to measure and monitor the effectiveness of the cyber resilience strategy and framework, as well as its evolution over time. Relevant information and indicators could include, for example:

Compliance Gap Analysis Report - 2026-04-11

Recommendations

Based on the gap analysis, the following recommendations are made:

- 1. IMMEDIATE: Address all critical gaps within 30 days
- 2. SHORT-TERM: Resolve high priority gaps within 90 days
- 3. MEDIUM-TERM: Address medium priority gaps within 180 days
- 4. ONGOING: Implement continuous monitoring and improvement
- 5. TRAINING: Provide compliance training to relevant staff
- 6. DOCUMENTATION: Update policy documentation to reflect changes

Action Items and Timeline

? Critical Priority

Action: Implement missing security controls
Timeline: 30 days

? High Priority

Action: Update policy documentation
Timeline: 60 days

? Medium Priority

Action: Conduct staff training
Timeline: 90 days

Compliance Gap Analysis Report - 2026-04-11

Next Steps

1. Review this report with executive stakeholders
2. Assign ownership for each identified gap
3. Develop detailed remediation plan
4. Schedule follow-up assessment in 90 days
5. Implement continuous monitoring process